

MIGUEL ANGEL SALAZAR MARTINEZ

Universidad Politécnica de San Luis Potosi

CNO 4 – Seguridad Informática

Profesor: Servando López Contreras

Actividad 11 – File Path Traversal | Validation of
start of path

24/09/26

Introducción

En el ámbito de la ciberseguridad, el juego entre ataque y defensa a menudo se decide en la oportunidad de la validación. En la sección anterior vimos cómo evadir filtros mediante doble codificación; ahora, el escenario que nos ocupa revela otro defecto lógico común: solo se verifica el "inicio" de la ruta, pero se ignora el "destino final". Cuando la aplicación exige que la entrada comience con un "directorio de confianza" pero no comprueba dónde acaba realmente la ruta después de resolver los ../, el atacante solo necesita añadir secuencias de traversal después del prefijo legítimo para escapar del sandbox. Este caso demuestra con claridad que validar una propiedad no es validar todo; comprobar el punto de partida de una ruta no es comprobar su punto de llegada.

Marco Teórico

El defecto lógico de la validación por prefijo

El núcleo de este laboratorio es la "validación del inicio de la ruta". La aplicación, al recibir la ruta de archivo proporcionada por el usuario, comprueba si esa ruta comienza con un directorio esperado (como `/var/www/images/`). Si no es así, rechaza la petición. Esta regla parece segura: si el usuario solo puede acceder a archivos dentro del directorio de imágenes, no podrá leer otros archivos.

Sin embargo, "comenzar con un prefijo" solo garantiza una cosa: los primeros caracteres de la cadena cumplen el requisito. No impone ninguna restricción sobre lo que viene después. El atacante puede conservar el prefijo legítimo y añadir después secuencias de traversal, haciendo que la ruta final resuelta apunte a una ubicación completamente distinta.

Cómo las secuencias de traversal evaden la validación por prefijo

La carga útil que construye el atacante es:

```
/var/www/images/../../../../etc/passwd
```

Cuando la aplicación verifica, ve que la ruta efectivamente comienza con `/var/www/images/` y la validación pasa. Pero después, el sistema resuelve las secuencias `../` de esa ruta.

La validación comprueba la cadena en el momento de la verificación, pero la operación del sistema de archivos usa la ruta final resuelta. Ambas apuntan a ubicaciones completamente diferentes.

La forma de defensa más segura

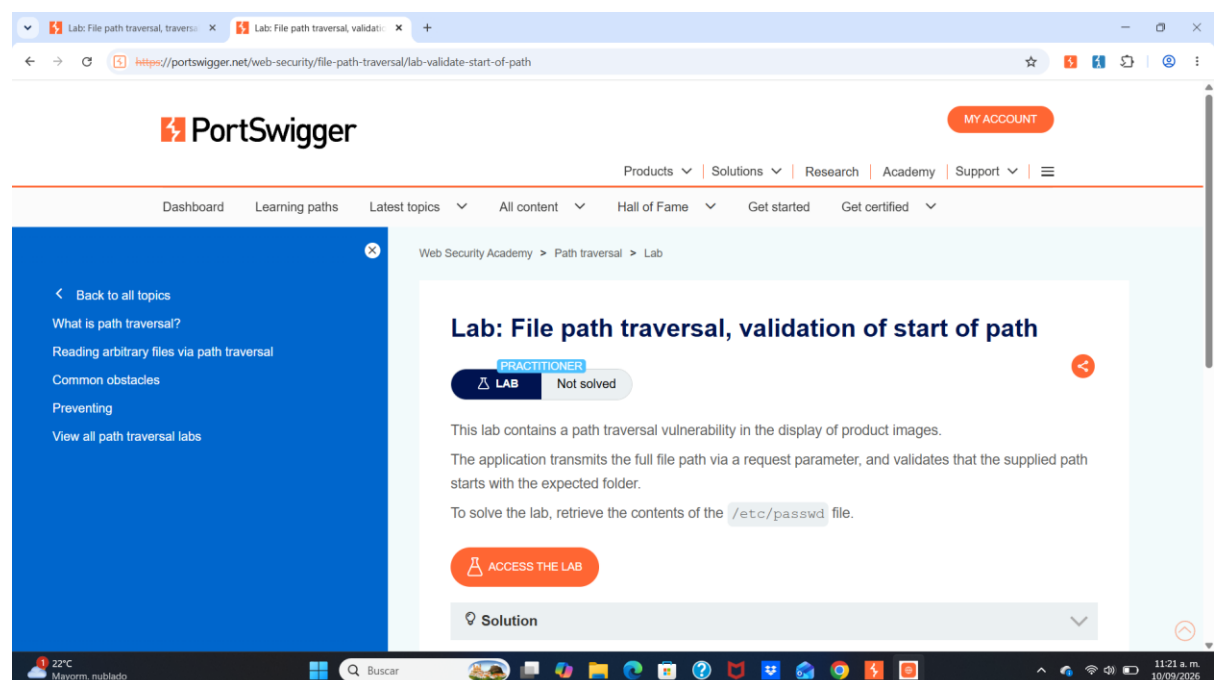
La práctica correcta es: normalizar primero la ruta y luego verificar si el resultado está dentro del directorio permitido. Por ejemplo, en Java se usa `getCanonicalPath()` y luego se comprueba si la ruta normalizada comienza con el directorio esperado. De esta forma, sin importar cuántos `../` inserte el atacante, la ruta final normalizada quedará al descubierto y será verificada.

Posibles Soluciones

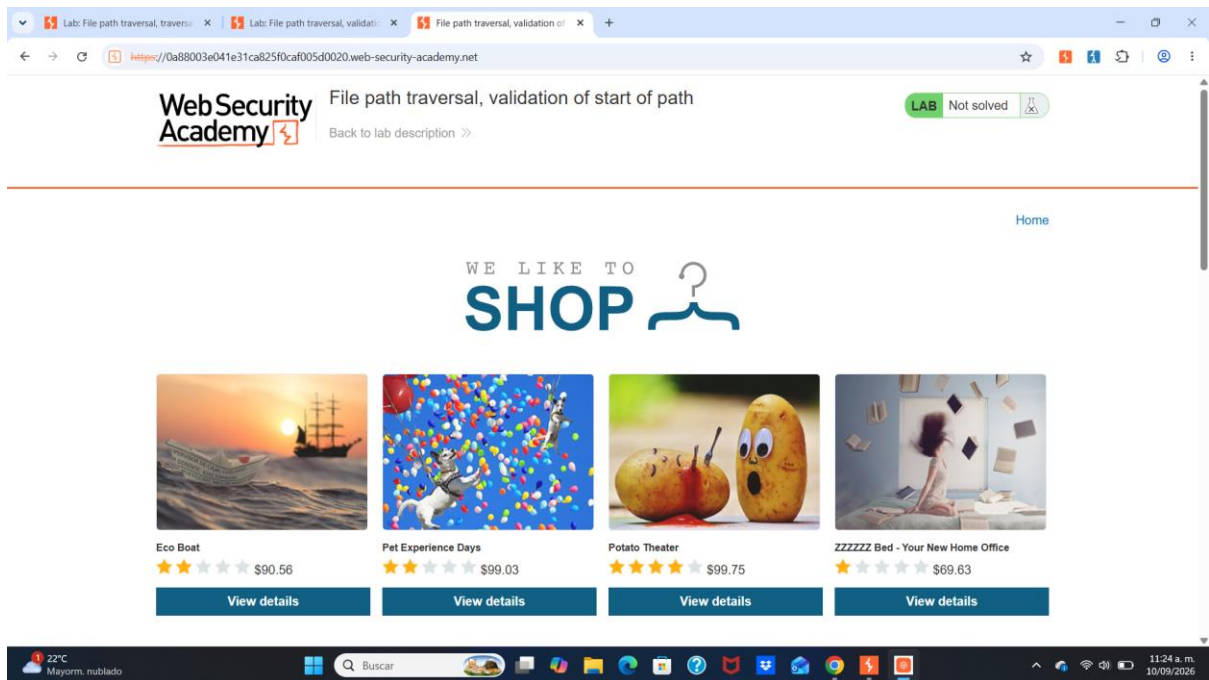
Soluciones para prevenir el Path Traversal con validación de inicio de ruta

Para evitar esta vulnerabilidad, la defensa no debe limitarse a verificar que la ruta comience con el directorio permitido, ya que un atacante puede conservar ese prefijo y añadir secuencias de traversal (../) para salir del directorio. La solución correcta consiste en normalizar primero la ruta completa (por ejemplo, con `realpath()` en PHP o `getCanonicalPath()` en Java) y luego verificar que la ruta resultante permanezca dentro del directorio permitido. Si la ruta normalizada no comienza con el directorio seguro, se rechaza la petición. Esta validación debe realizarse sobre el destino final, no sobre la entrada cruda, porque es el destino final lo que el sistema operativo usará para acceder al archivo.

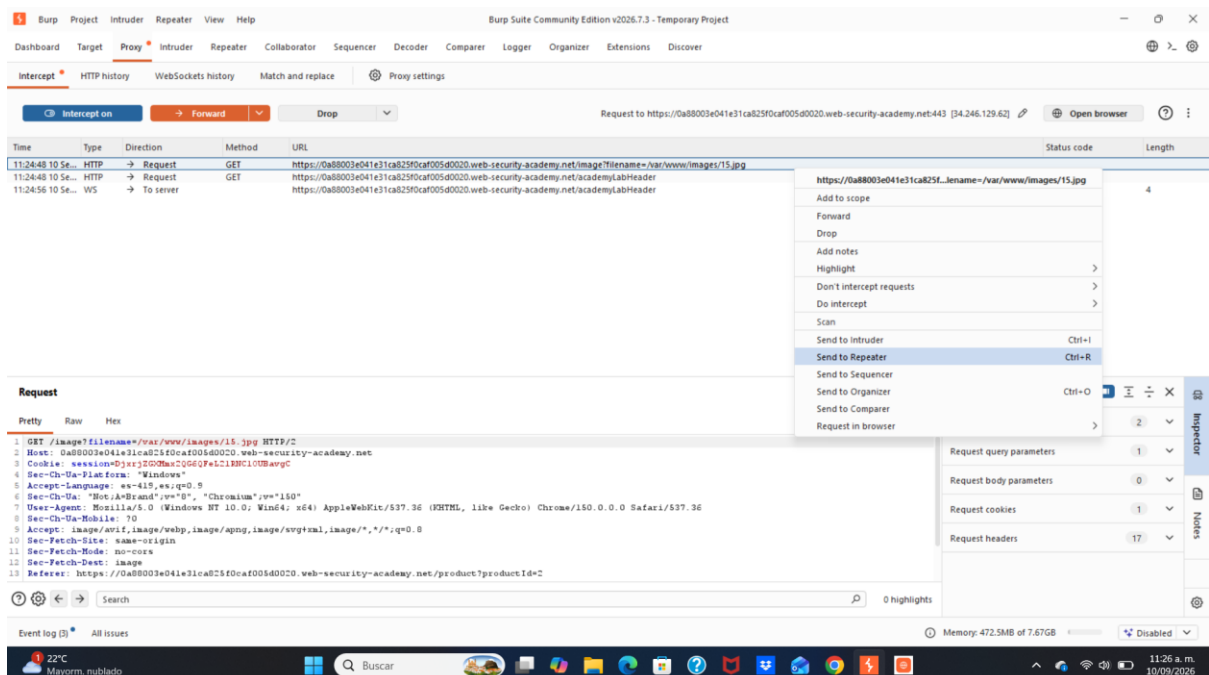
Desarrollo



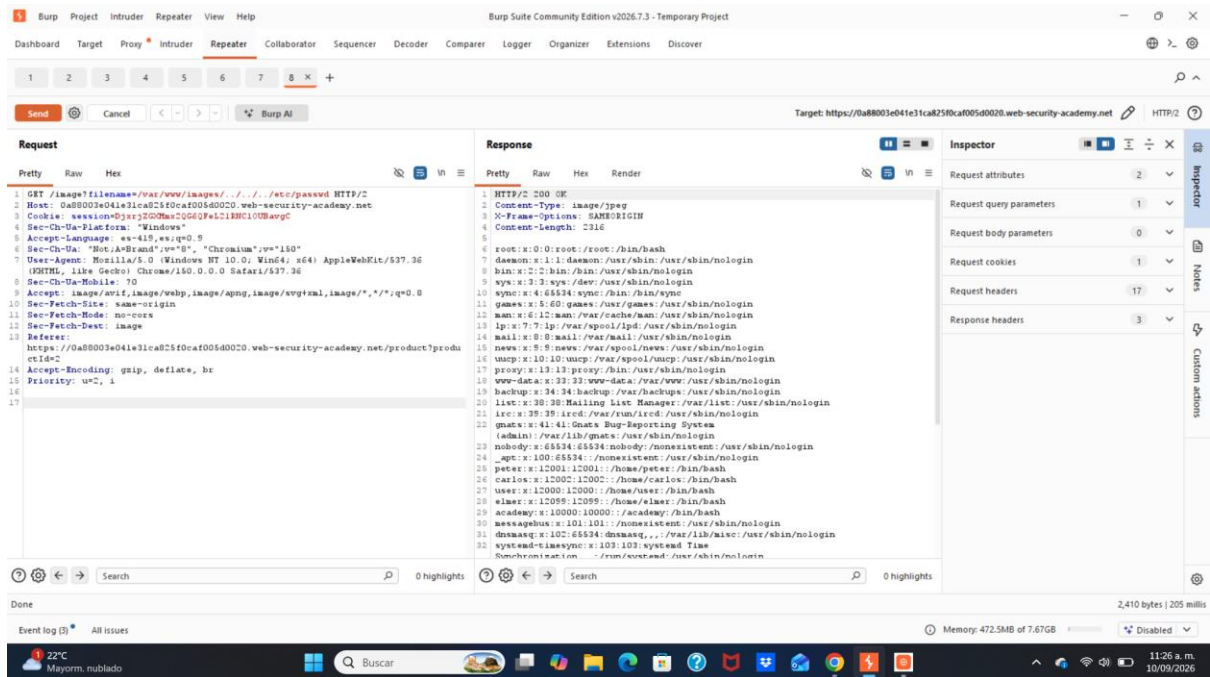
Para la actividad comenzamos copiando la URL de la actividad y pegándolo en el navegador que nos proporciona burp para ingresar a nuestra tarea de Validation of start of path.



Despues de dar click en “Access the lab” nos mandara directamente a la web que vamos a vulnerear para obtener los usuarios y passwords del sistema. Procedemos a dar click en el boton de “View Details” para comenzar a interceptar el trafico en nuestro burpsuit.



Justo después de presionar el botón de “view details” nos comenzara a llegar el tráfico, daremos en el botón de forward en los logs que no nos interesan hasta que nos aparezcan los que necesitamos que son los de tipo “img”. Una vez que encontremos el log de img lo seleccionamos y dando click derecho buscamos la opción que diga “Send to repeater” para mandarlo al repetidor que es donde lo analizaremos más a fondo.



Una vez estemos en la parte del repetidor analizaremos el log “img” nos daremos cuenta de que en la parte de filename, podemos acceder al directorio de passwords y usuarios, aprovechándonos de la vulnerabilidad de la validación de inicio de ruta. Esta vulnerabilidad consiste en que el sistema solo verifica el inicio de ruta que es “/var/www/images” es decir nosotros podríamos aprovecharnos de esto y escribir “/var/www/images/../../../../etc/passwd” y acceder directamente a los usuarios y sus contraseñas como se ve en el ejemplo.

Conclusión

Este laboratorio revela un principio importante sobre la validación de entradas: validar una parte de una propiedad no equivale a validar la propiedad completa. Comprobar si una ruta comienza con un directorio determinado solo garantiza que el prefijo de la cadena "parece correcto", pero no impone ninguna restricción sobre el destino final de la ruta. El atacante conserva el prefijo legítimo y añade secuencias de traversal después, logrando así pasar la validación y escapar del sandbox al mismo tiempo.

Desde la perspectiva del defensor, la práctica correcta es normalizar primero la ruta y luego validar el resultado normalizado. Utilizar las API del sistema de archivos que proporciona la plataforma (como `getCanonicalPath()` en Java o `GetFullPath()` en ASP.NET) para resolver la entrada del usuario en una ruta absoluta normalizada, y luego comprobar si esa ruta final está realmente dentro del directorio permitido. La validación debe realizarse después de completar la resolución de la ruta, no antes.